FIAP ON

ENSINO A DISTÂNCIA

GOVERNANÇA CORPORATIVA

COMO GERENCIAR RISCOS – O PADRÃO ISO 31000

Luiz Fraga

CAPÍTULO 4

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

LISTA DE FIGURAS

Figura 4.1 – Relacionamentos entre princípios, estrutura e processo da ISO 31000 4
Figura 4.2 – Relacionamentos entre princípios, estrutura e processo da ISO 31000 - Princípios 5
Figura 4.3 – Relacionamentos entre princípios, estrutura e processo da ISO 31000 - Estrutura 7
Figura 4.4 – Componentes da estrutura de gestão de riscos do padrão ISO 31000 . 8
Figura 4.5 – Processo de gestão de risco do padrão ISO 31000 11
Figura 4.6 – Mapa de risco 13

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

SUMÁRIO

4 COMO GERENCIAR RISCOS – O PADRÃO ISO 31000 4
4.1 Princípios da gestão de riscos.....5
4.2 Estrutura para gestão de riscos.....7
4.3 Processo para gestão de riscos 10
4.3.1 Escopo, contexto e critério 11
4.3.2 Processo de avaliação de riscos 11
4.3.3 Tratamento de riscos.....14
4.3.4 Monitoramento e análise crítica.....15
4.3.5 Comunicação e consulta 15
4.3.6 Registro e relato 16
REFERÊNCIAS.....17

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

4 COMO GERENCIAR RISCOS – O PADRÃO ISO 31000

A ISO considera que todas as atividades realizadas por uma organização, em quaisquer de seus níveis hierárquicos, estão envolvidas com riscos. Por isso, a entidade desenvolveu um processo sistemático e genérico para a gestão de riscos que pode ser adaptado por organizações de qualquer porte ou segmento econômico. Foi criado, assim, o padrão ISO 31000 (ABNT, 2018).

Se uma organização adota o padrão ISO 31000, ela se torna capaz de identificar, analisar, avaliar e tratar os riscos inerentes ao seu negócio de forma sistêmica para atender às suas necessidades e alcançar seus objetivos. Isso inclui atividades de comunicação entre todos os *stakeholders* e o contínuo monitoramento dos riscos para assegurar um tratamento adequado de cada risco ao longo do tempo.

O padrão ISO 31000 está organizado em três grandes partes mostradas a seguir (Figura Relacionamentos entre princípios, estrutura e processo da ISO 31000):

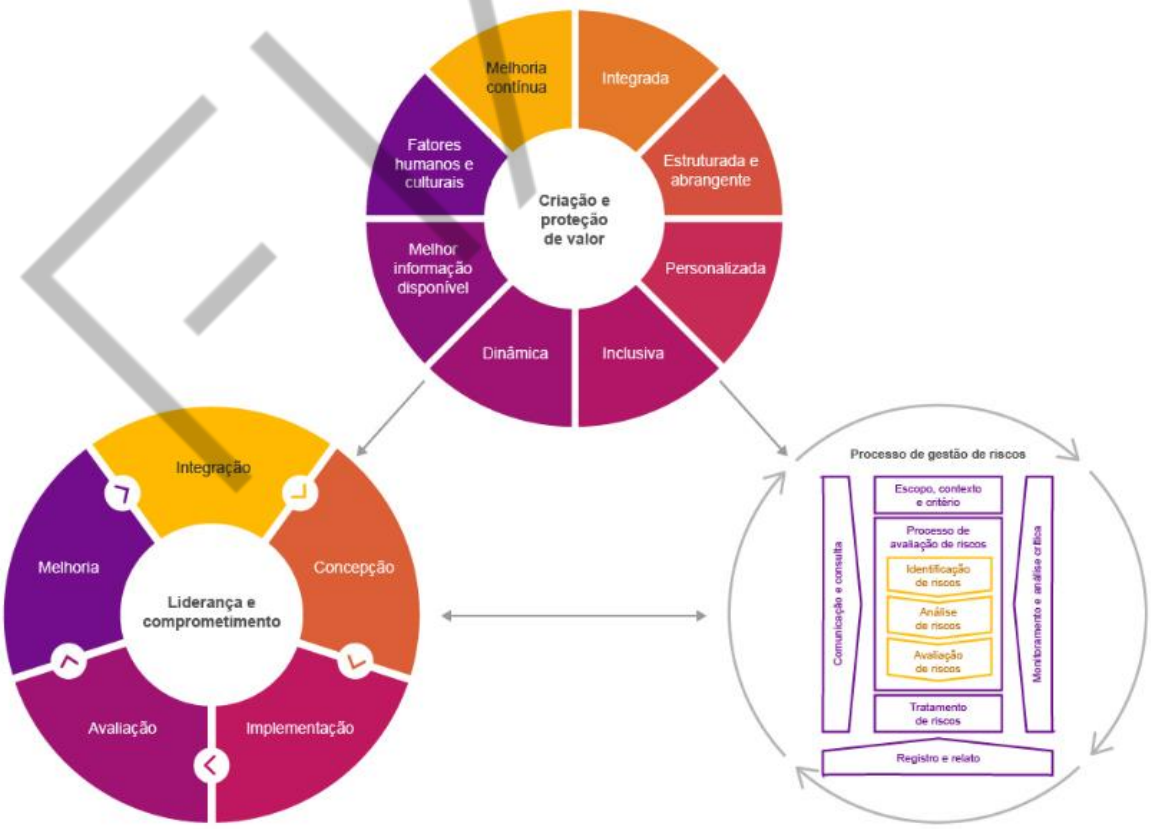

Figura 4.1 – Relacionamentos entre princípios, estrutura e processo da ISO 31000
Fonte: ABNT (2018), adaptado por FIAP (2020)

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Cada uma das partes será detalhada nas próximas seções.

4.1 Princípios da gestão de riscos

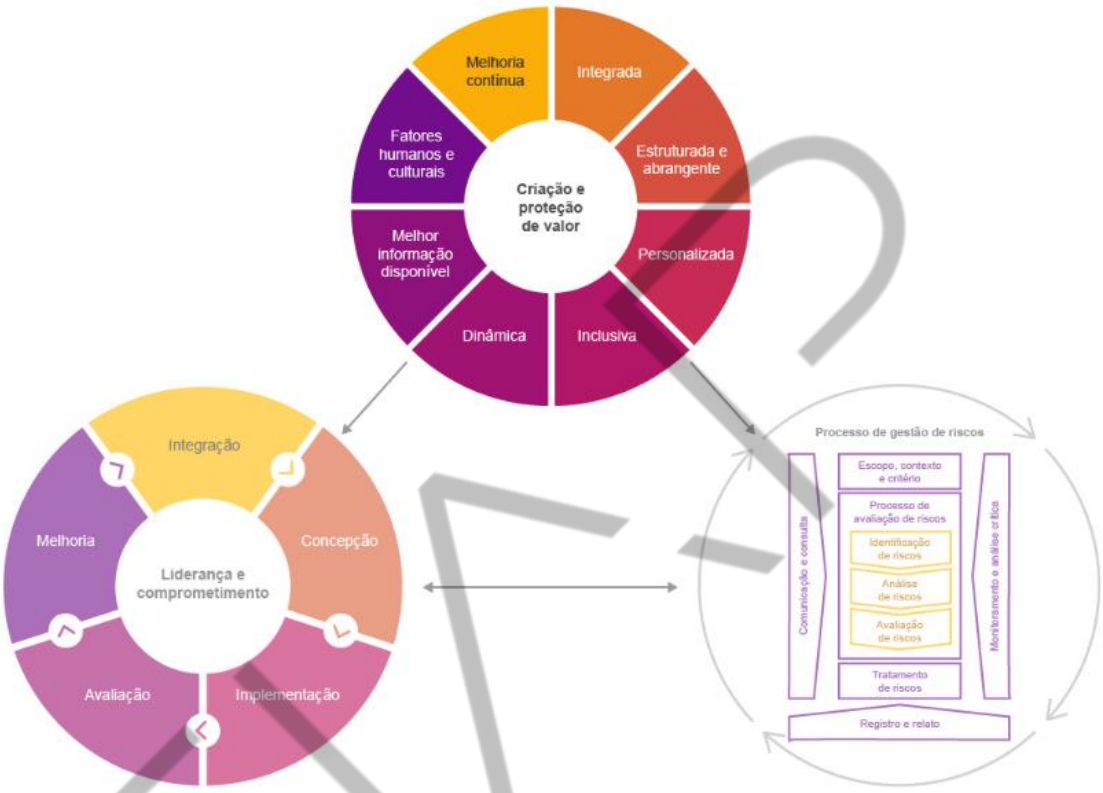

Figura 4.2 – Relacionamentos entre princípios, estrutura e processo da ISO 31000 - Princípios
Fonte: ABNT (2018), adaptado por FIAP (2020)

Para garantir a eficácia da gestão de riscos, o padrão ISO 31000 estabelece alguns princípios, centrados na criação e proteção de valor, a serem atendidos por todos os níveis da organização:

a) **Integrada:** a gestão de riscos não pode ser autônoma, mas deve fazer parte das responsabilidades de todos os colaboradores e, inclusive, abranger o planejamento estratégico, a gestão de projetos, mudança e operações.

b) **Estruturada e abrangente:** para obtenção de consistência, comparabilidade e confiabilidade nos resultados da gestão de riscos.

c) **Personalizada:** a gestão de riscos precisa estar alinhada e proporcional aos contextos interno e externo da organização, relacionando-se aos seus objetivos.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

d) **Inclusiva:** envolvimento apropriado e oportuno de todos os *stakeholders* para garantir que suas expectativas e opiniões sejam levadas em conta no tratamento dos riscos. Assim, é possível uma melhor conscientização e gestão de riscos fundamentada.

e) **Dinâmica:** a gestão de riscos deve antecipar, detectar, reconhecer e responder às mudanças dos riscos, considerando os contextos internos e externos de uma empresa.

f) **Melhor informação disponível:** a gestão de riscos deve se basear em dados históricos, experiências, *feedbacks* de *stakeholders*, observações, previsões e opiniões de especialistas, considerando-se suas limitações e a possibilidade de divergências.

g) **Fatores humanos e culturais:** capacidades, percepções e intenções de pessoas internas e externas à organização podem facilitar ou não o processo.

h) **Melhoria contínua:** à medida que amadurece, por meio de aprendizados e experiências, a gestão de riscos suporta a melhoria de outros processos da organização.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

4.2 Estrutura para gestão de riscos

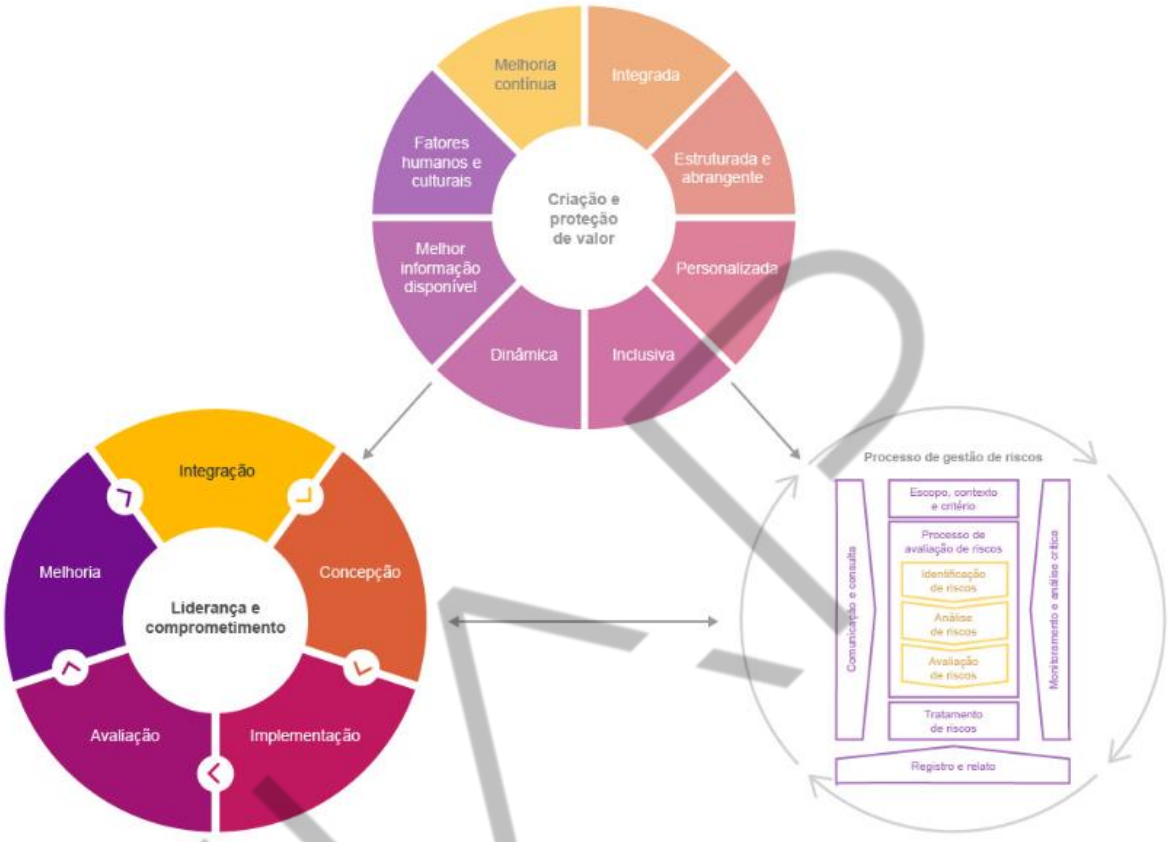

Figura 4.3 – Relacionamentos entre princípios, estrutura e processo da ISO 31000 - Estrutura
Fonte: ABNT (2018), adaptado por FIAP (2020)

A estrutura é uma parte crítica para o sucesso da gestão de riscos, pois ela deve garantir os recursos e arranjos necessários para a boa execução do processo. Ela deve contar com seis elementos (Figura Componentes da estrutura de gestão de riscos do padrão ISO 31000), que serão explicados a seguir.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Figura 4.4 – Componentes da estrutura de gestão de riscos do padrão ISO 31000
Fonte: ABNT (2018), adaptado por FIAP (2020)

- O primeiro componente – **Liderança e comprometimento** – diz respeito ao compromisso da alta direção e órgãos de supervisão em garantir:Personalizar e implementar todos os componentes da estrutura;
- Definir uma declaração ou política para determinar uma abordagem, plano ou curso de ação da gestão de riscos;
- Alocação dos recursos necessários para a gestão de riscos;
- Atribuição de responsabilidades sobre a gestão de riscos nos níveis organizacionais adequados.

Com isso, será possível na organização:

- Alinhamento dos objetivos da gestão de riscos com os objetivos, estratégias e cultura da organização;
- Reconhecer e abordar as obrigações e compromissos voluntários;

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Estabelecer a quantidade e o tipo de risco que pode ser assumido ou não, para orientar o desenvolvimento de critérios, assegurando que sejam informados à organização e aos seus *stakeholders*;
- Comunicação do valor da gestão de riscos para a organização e para os seus *stakeholders;*
- Promover o monitoramento sistemático de riscos;
- Assegurar que a estruturação de gestão de riscos mantenha-se apropriada ao contexto da organização.

O componente **Integração** apoia-se em compreensão das estruturas e do contexto organizacional. Cada organização tem uma estrutura definida de acordo com seu propósito, metas e complexidade e o risco é gerenciado em todas as partes estruturais da organização. A integração da gestão de riscos em uma organização requer um processo dinâmico e iterativo, e é indicado que seja personalizado para atender às necessidades e cultura organizacional. O ideal é que a gestão de riscos seja parte do propósito organizacional, governança, liderança e comprometimento, estratégia, objetivos e operações.

A **Concepção** está relacionada ao planejamento detalhado da estrutura para a gestão de riscos e engloba as seguintes atividades macro:

- **Entendendo a organização e seu contexto:** envolve a avaliação e a compreensão dos ambientes interno e externo em sentido amplo com o mapeamento dos *stakeholders,* da estrutura organizacional, de aspectos culturais e políticos, do modelo de governança e tomada de decisão e das capacidades da organização (pessoas, processos e tecnologia) etc.
- **Articulando o comprometimento com a gestão de riscos**: inclui a definição clara da política, dos objetivos, das responsabilidades, dos recursos necessários, dos mecanismos de monitoração de desempenho, do tratamento de conflitos e da melhoria contínua da gestão de riscos.
- **Atribuindo papéis organizacionais, autoridades, responsabilidades e responsabilizações:** identificar as pessoas da organização que terão papéis no processo de gestão de riscos e atribuir a elas a responsabilidade e a devida autoridade para o exercício efetivo deste papel.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- **Alocando recursos:** identificação dos recursos necessários ao processo de gestão de riscos, incluindo pessoas e respectivas competências requeridas, métodos, ferramentas, sistemas de informação, treinamentos etc.
- **Estabelecendo comunicação e consulta:** definição dos conteúdos, formatos, meios e frequência das comunicações para os *stakeholders* internos, visando a divulgação oportuna e pontual de informações derivadas da gestão de riscos e o apoio e incentivo à responsabilização e propriedade dos riscos.

O componente **Implementação** tem como objetivo materializar o uso da política e do processo de gestão de riscos na organização por meio de treinamento, da alocação efetiva de recursos e da execução do plano de riscos.

A **Avaliação** é é responsável pela medição e análise dos indicadores do processo de gestão de risco e pela identificação de oportunidades de melhoria.

O último componente – **Melhoria** – é o responsável pela elaboração de um plano de melhoria para a política, plano e estrutura da gestão de riscos, a partir das oportunidades identificadas pelo monitoramento e análise crítica da estrutura.

4.3 Processo para gestão de riscos

O processo de gestão de riscos especificado pela ISO 31000 deve ser incorporado à cultura, às práticas e nos processos de gestão da organização, bem como adaptado aos processos de negócio.

O processo está dividido em fases (Figura Processo de gestão de risco do padrão ISO 31000), que serão descritas a seguir:

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

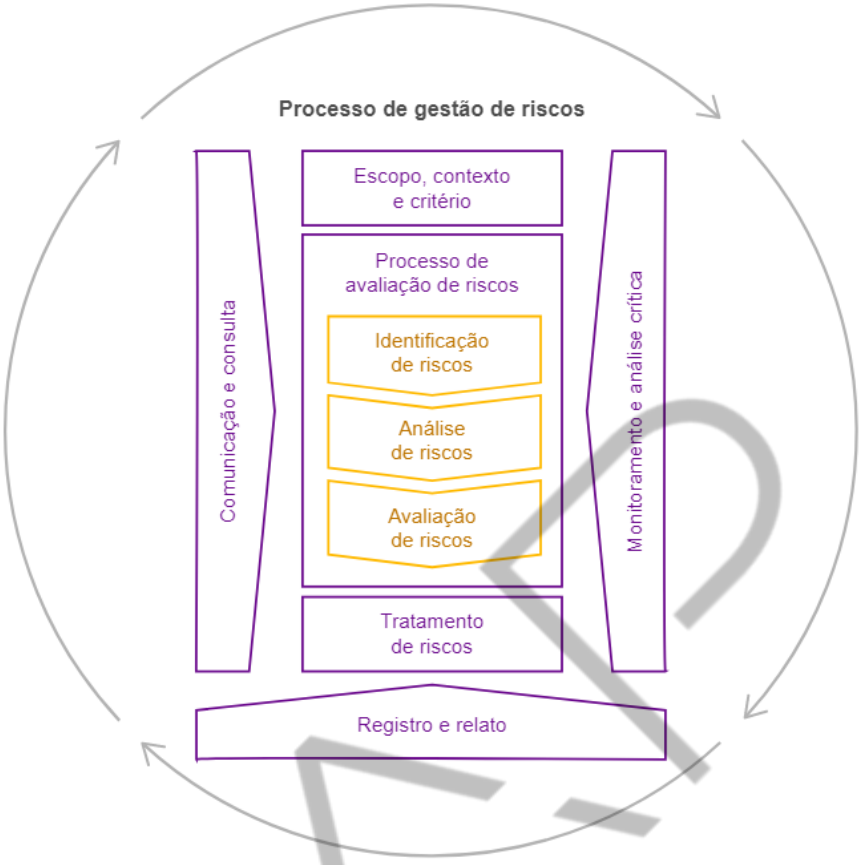

Figura 4.5 – Processo de gestão de risco do padrão ISO 31000
Fonte: ABNT (2018), adaptado por FIAP (2020)

4.3.1 Escopo, contexto e critério

Esta fase é responsável pela personalização do processo de gestão de riscos, permitindo um processo eficaz de avaliação e tratamento de riscos. Contempla a definição do escopo do processo, a compreensão dos contextos externo e interno e definição de critérios de risco.

4.3.2 Processo de avaliação de riscos

Esta fase é central no processo e engloba três etapas importantes para a identificação, a análise e a própria avaliação de riscos.

A primeira etapa é a **identificação de riscos** e tem como objetivo elaborar uma lista de riscos abrangente e detalhada. A organização pode possuir diversas técnicas para identificar incertezas que poderão afetar um ou mais objetivos. Alguns fatores e o relacionamento entre eles podem ser considerados:

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Fontes tangíveis e intangíveis de risco;
- Causas e eventos;
- Ameaças e oportunidades;
- Vulnerabilidades e capacidades;
- Mudanças nos contextos externo e interno;
- Indicadores de riscos emergentes;
- Natureza e valor dos ativos e recursos;
- Consequências e seus impactos nos objetivos;
- Limitações de conhecimento e de confiabilidade da informação;
- Fatores temporais;
- Vieses, hipóteses e crenças dos envolvidos.

Todas as possíveis fontes de risco devem ser mapeadas pela organização, mesmo aquelas que não estejam sob seu controle. Um outro ponto importante é o exame de reações em cadeia provocadas por efeitos específicos. Como exemplo de uma reação em cadeia, temos a demissão dos funcionários da Embraer após o 11 de setembro.

Para identificação de riscos pode-se usar várias técnicas, como o uso de *checklists*, bases de lições aprendidas, *brainstorming*, opinião de especialistas, entrevistas, reuniões etc. É importante que o máximo de pessoas apropriadas seja envolvido nessa fase, incluindo pessoas de fora da organização sempre que necessário, pois muitos dos riscos podem estar associados a fornecedores, clientes e parceiros de negócios. Quanto maior o número de riscos identificados e maior a quantidade de detalhes sobre eles, melhor tende a ser o resultado desta etapa.

A segunda etapa é a **análise de riscos**, cujo objetivo é compreender cada risco identificado a partir da apreciação de suas causas, consequências e probabilidades. Nessa etapa, deve-se empregar uma escala padronizada, seja ela numérica ou qualitativa (com atributos de classificação do tipo baixo, médio e alto), para se determinar os níveis de probabilidade e de impacto de cada evento identificado e, em seguida, combiná-los para ver o nível de risco.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

Uma ferramenta comum para esta etapa é o uso de Mapas de Risco (Figura Mapa de risco):

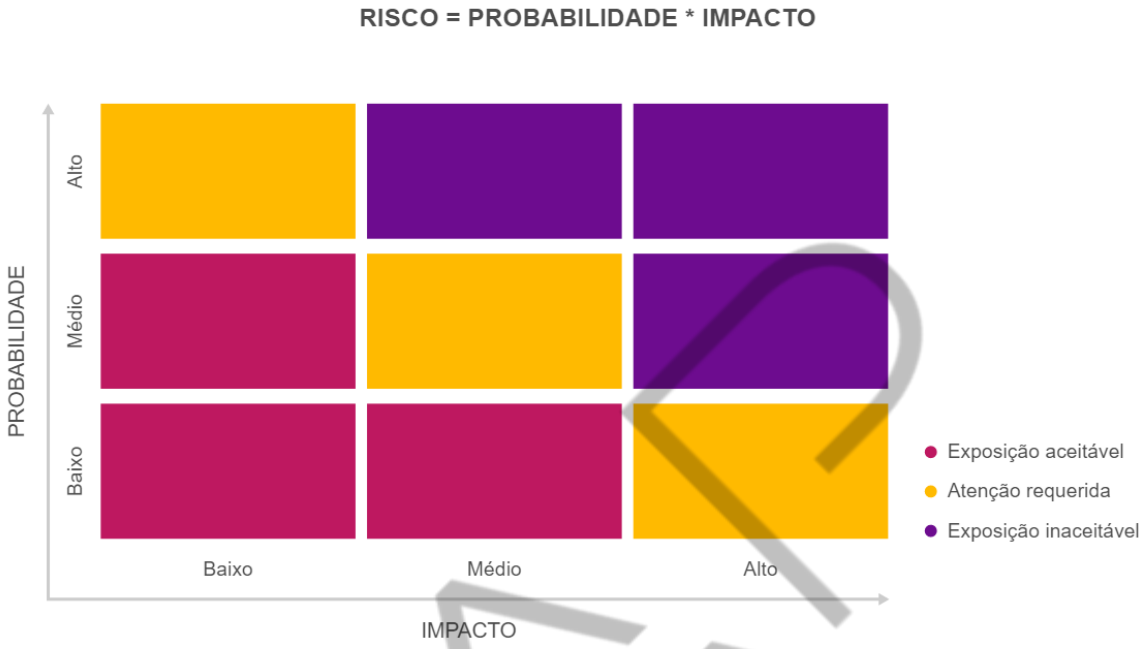

Figura 4.6 – Mapa de risco
Fonte: Elaborado pelo autor (2017), adaptado por FIAP (2020)

Basicamente, o Mapa de Risco trabalha com a combinação de Probabilidade X Impacto de um Risco e pode assumir diversas escalas dentro dos dois eixos de acordo com a política da organização que o aplica. Por exemplo, se um dado risco apresentar alta probabilidade de ocorrência e alto nível de impacto, sua severidade será crítica.

Em geral, o resultado da etapa de análise de risco é a lista de riscos classificada.

A terceira e última etapa é a de **avaliação de riscos**, cujo objetivo é definir quais riscos precisam ser priorizados para tratamento, sendo um grande suporte para a tomada de decisões.

Basicamente, avalia-se o nível de risco e demais informações, tomando-se como base os parâmetros e critérios de risco estabelecidos pela organização, tais como o nível de tolerância a risco e requisitos legais, regulatórios ou de controles internos.

Deve-se considerar o contexto mais amplo e as consequências reais e percebidas para os *stakeholders* externos e internos. Por fim, é conveniente que o

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

resultado da avaliação de riscos seja registrado, comunicado e validado nos níveis apropriados da organização.

4.3.3 Tratamento de riscos

Esta fase diz respeito às decisões sobre o tratamento a ser dado para cada risco identificado, analisado e avaliado. Normalmente, as opções de tratamento para riscos envolvem as seguintes ações:

- Evitar o risco ao não iniciar ou descontinuar uma atividade que pode materializá-lo.
- Tomar ou aumentar o risco, quando se trata de oportunidade.
- Remover a fonte de risco.
- Alterar a probabilidade de ocorrência.
- Alterar as consequências (reduzir ou modificar o impacto).
- Compartilhar ou transferir o risco com outras partes.
- Reter o risco por decisão fudamentada.

Se as opções de tratamento afetam vários *stakeholders*, eles devem ser envolvidos na decisão. É importante considerar que uma determinada ação de tratamento pode introduzir novos riscos, que também precisam ser avaliados e monitorados.

- Uma outra atividade desta fase é a elaboração do plano para tratamento de riscos, que deve conter as seguintes informações:Racional das ações de tratamento – por que foram escolhidas.
- Responsáveis pela aprovação do plano.
- Responsáveis pela implementação do plano.
- Ações a serem executadas.
- Os recursos necessários, incluindo contingências.
- Medidas de desempenho e restrições.
- Requisitos para a apresentação de informação e monitoramento.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

- Cronograma e programação.

É importante que os planos de tratamento sejam integrados aos demais processos da organização conforme necessidade. Por exemplo, pode ser necessário ter aprovação financeira do plano e sua execução estar sujeita ao processo de gestão de mudança.

Os planos precisam estar bem comunicados a todos os envolvidos e sua execução pode ser invocada pela atividade de monitoramento e análise crítica que será explicada a seguir.

4.3.4 Monitoramento e análise crítica

Esta fase assegura a verificação regular dos riscos identificados, analisados e avaliados com a finalidade de manter o registro de riscos atualizado e, especialmente, de acionar a execução do plano de tratamento de risco sempre que necessário. Por isso, ela deve ocorrer de forma concomitante com as outras fases. Além disso, as atividades de monitoramento devem garantir que:

- os controles sejam eficazes e eficientes tanto para projetos como operações regulares;
- seja obtida informação adicional para a avaliação de riscos;
- eventos, mudanças, tendências, sucessos e fracassos sejam analisados e as lições aprendidas registradas;
- se detectem mudanças nos contextos interno e externo, tanto nos critérios de risco como nas condições dos riscos, porque elas podem ocasionar nova análise, avaliação e tratamento;
- sejam detectados novos riscos e disparada a identificação deles.

4.3.5 Comunicação e consulta

Esta fase deve ser realizada em paralelo às demais fases do processo de gestão de risco, porque a comunicação é contínua. Por exemplo, a lista de riscos identificados deve ser comunicada a todos os *stakeholders* relevantes, assim como

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

as listas de riscos analisados e priorizados, e da mesma forma os planos de tratamento de riscos.

Além disso, cabe à comunicação garantir que todos os *stakeholders* internos e externos tenham o conhecimento apropriado do processo de gestão de riscos, bem como dos parâmetros e definições de risco adotados pela organização.

4.3.6 Registro e relato

É importante que o processo de gestão de riscos, bem como seus resultados, seja documentado e relatado de forma apropriada. Esse processo tem como objetivos:

- Relatar atividades e resultados de gestão de riscos para toda a organização;
- Disponibilizar informações para a tomada de decisão;
- Melhorar as atividades de gestão de riscos;
- Dar suporte na interação com os stakeholders, inclusive aqueles com relação direta – responsabilidade ou responsabilização – por atividades de gestão de riscos.

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com

REFERÊNCIAS

ABNT. **ABNT ISO Guia 73:** gestão de riscos – vocabulário. São Paulo: ABNT, 2009.

ABNT. **ABNT NBR ISO 31000:** gestão de riscos – princípios e diretrizes. São Paulo: ABNT, 2018.

ASSI, M. **Gestão de riscos com controles internos**: ferramentas, certificações e métodos para garantir a eficiência dos negócios. São Paulo: Saint Paul, 2012.

BERNSTEIN, P.L. **Desafio aos deuses**: a fascinante história do risco. 16. ed. Rio de Janeiro: Campus, 1997.

IBGC. **Guia de orientação para o gerenciamento de riscos corporativos**. São Paulo: IBGC, 2007.

SAXON, Wolfgang. Arthur Rudolph, 89, developer of rocket in first Apollo flight. **The New York Times**. Nova York, 3 jan. 1996. Disponível em: <http://www.nytimes.com /1996/01/03/us/arthur-rudolph-89-developer-of-rocket-in-first-apollo-flight.html>. Acesso em: 21 abr. 2020.

FIAP

PDF exclusivo para Francismar Alves Martins Júnior - rm562869
yggdrasil.git@gmail.com